



重庆人文科技学院
Chongqing College of Humanities, Science & Technology

《人工智能概论》

课程设计报告

题 目	人工智能概论
学 院	人工智能与信息安全学院
专 业	信息安全
年 级	2023 级
学 号	20230158064
姓 名	万庭宇
指导教师	刘艳

2026 年 5 月

目 录

摘 要 5

1 引言 5

2 大模型与安全运营概述 5

 2.1 大语言模型技术发展 5

 2.2 安全运营的核心需求与挑战 5

3 大模型在安全运营中的核心应用场景 6

 3.1 威胁检测与智能分析 6

 3.2 安全事件自动化响应 6

 3.3 日志异常检测与根因分析 6

 3.4 安全威胁情报分析 6

 3.5 自动化渗透测试与漏洞验证 7

 3.6 业务逻辑漏洞检测与应用案例 7

 3.6.1 越权访问检测 7

 3.6.2 支付与交易逻辑漏洞检测 7

 3.6.3 业务流程绕过检测 8

 3.6.4 技术实现架构 8

4 关键技术与实现架构 8

 4.1 检索增强生成技术在安全知识库中的应用 8

 4.2 智能体在安全自动化中的应用 8

 4.3 提示工程与安全任务优化 9

5 安全风险与伦理规范 9

5.1 大模型自身安全风险 9

5.2 数据隐私与合规考量 9

5.3 AI 伦理与安全运营中的人机关系..... 9

6 未来展望 9

7 结论 10

摘要

大语言模型（LLM）凭借强大的自然语言理解和推理能力，正在深刻改变网络安全运营的传统范式。本文梳理了大模型在安全运营中的核心应用场景，涵盖威胁检测、业务逻辑漏洞挖掘、事件响应、日志异常分析、威胁情报处理和自动化渗透测试等领域，重点论述了大模型在业务逻辑漏洞检测中的独特优势——通过业务语义理解而非特征匹配发现隐藏在正常交互中的逻辑缺陷。在此基础上，本文分析了提示工程、RAG 和智能体架构等关键技术的落地路径，探讨了大模型自身安全风险与伦理规范，并展望了未来发展方向。

1 引言

网络安全威胁日益复杂，传统基于规则的安全运营体系面临告警过载、人才短缺和攻击手段自动化的多重挑战。大语言模型（LLM）凭借强大的自然语言理解和推理能力，天然适配安全运营中理解攻击链、分析日志、生成检测规则和辅助事件调查等核心需求。安全运营本质是信息密集型工作流，而大模型擅长的正是信息理解与生成，二者的结合具有天然适配性。本文围绕大模型在安全运营中的具体应用展开论述，探讨其技术原理、实现路径及面临的挑战。

2 大模型与安全运营概述

2.1 大语言模型技术发展

大语言模型从统计语言模型演进至基于 Transformer 架构的预训练大模型。2017 年自注意力机制奠定了技术基础，2022 年 ChatGPT 引发全球研究热潮。当前主流大模型采用仅解码器 Transformer 架构，通过自回归预训练、指令微调和 RLHF 实现与人类意图对齐，核心能力包括自然语言理解与生成、上下文学习以及涌现的链式推理和规划能力。安全领域已涌现 SecurityBERT、SecureBERT 等垂直大模型，在威胁检测和恶意代码分析上展现出优于通用模型的性能。

2.2 安全运营的核心需求与挑战

安全运营通过人员、流程和技术持续监测和响应安全威胁，核心机制为“采集-检测-分析-响应”。当前面临告警疲劳、人才短缺、攻击手段自动化和安全知识分散等挑战，症结在于需分析的数据量远超人类认知上限。大模型强大的信息理解和生成能力为弥合这一鸿沟提供了新可能。

3 大模型在安全运营中的核心应用场景

3.1 威胁检测与智能分析

威胁检测是大模型最先赋能的领域。传统签名匹配对未知威胁和变形攻击无能为力，大模型通过语义理解识别攻击意图，在 Web 攻击检测上准确率达 95%以上，显著优于 WAF。在恶意代码分析方面，大模型能解析反汇编代码和 API 调用序列生成恶意行为报告，并辅助生成 YARA 和 Sigma 检测规则。在钓鱼邮件检测方面，大模型从语义层面识别社会工程学攻击，比关键词匹配更精准。

3.2 安全事件自动化响应

安全事件响应最需要专业经验，也是大模型发挥推理能力的核心场景。在调查辅助方面，安全分析师可将告警上下文、日志片段和资产信息输入大模型，模型自动梳理攻击时间线，结合 ATT&CK 框架给出攻击链推断，将数小时的调查工作缩短到分钟级。在剧本生成方面，大模型根据事件类型自动生成 SOAR 响应剧本——例如对钓鱼事件自动生成邮件撤回、用户排查、IOC 封禁和终端扫描等步骤——并结合智能体框架驱动 SOAR 平台执行部分处置操作，实现从检测到响应的半自动化闭环。

3.3 日志异常检测与根因分析

企业 IT 环境每日产生海量异构日志，传统方法需为每种格式编写专用解析规则。大模型能自动识别异构日志格式并提取关键字段，发现偏离正常模式的异常事件并给出自然语言解释。在根因分析方面，大模型接收多源告警和日志，通过链式推理识别事件间因果关系，帮助快速定位问题根源，缩短平均检测和响应时间。

3.4 安全威胁情报分析

威胁情报多以非结构化文本形式存在，分析师提取效率低下。大模型可自动生成含攻击者身份、攻击手法和防御建议的结构化摘要，从文本中自动提取 IP、域名、文件哈希等 IOC 并按类型归类，跨多份报告关联分析以发现共性特征，使分析师能快速把握情报核心并将 IOC 对接安全设备。

3.5 自动化渗透测试与漏洞验证

传统渗透测试高度依赖个人经验。大模型可根据漏洞描述自动生成 Payload 或 PoC 脚本辅助验证，并根据已有目标信息推荐横向移动路径和提权方法，帮助渗透测试人员发现可能被忽视的攻击面。

3.6 业务逻辑漏洞检测与应用案例

业务逻辑漏洞是增长最快的 Web 安全威胁之一，源于应用程序流程设计缺陷而非代码缺陷。攻击者以合法接口、符合语法但违背业务意图的方式实现越权访问、参数篡改、支付欺诈和流程绕过。OWASP 将其列为核心风险。该类漏洞隐藏在正常业务交互中，不产生特征性载荷，传统 WAF 和签名检测几乎完全无法识别。大模型的语义理解和上下文推理能力，恰恰填补了这一检测盲区。

3.6.1 越权访问检测

越权分为水平越权（同级用户互访数据）和垂直越权（低权限执行高权限操作）。传统防御依赖逐 API 权限规则配置，大型应用中疏漏难以避免。大模型通过理解业务上下文判断 API 调用合理性。以电商平台为例：当用户 A 请求“GET /api/orders/10086”，大模型综合评估其身份、订单归属和历史行为基线，判断存在水平越权嫌疑并生成附带推理链路的告警——传统 WAF 仅能看到合法 GET 请求。在复杂场景中，大模型通过 RAG 接入岗位职责文档，能区分合法管理行为与权限滥用，实现精准的越权检测。

3.6.2 支付与交易逻辑漏洞检测

支付逻辑漏洞涵盖价格篡改、优惠券滥用、运费绕过等变种，攻击在 HTTP 层完全合法却在业务语义上构成欺诈。典型如价格篡改：后端未校验服务器端价格，攻击者将单价改为 0.01 元完成购买，基于规则的安全设备完全无法识别。大模型从多维度评估业务合理性：市场价与实付金额是否偏离、消费历史与订单是否匹配、优惠券组合是否合规、地理位置和操作时间是否与用户画像一致。并发竞态条件中，攻击者在毫秒级窗口重复提交提现请求，大模型通过 API 调用序列时间模式分析来识别，判断依据不是速率阈值，而是“同一用户为何在 0.1 秒内提交五次相同请求”这一行为的业务不合理性。

3.6.3 业务流程绕过检测

流程绕过指攻击者跳过关键步骤绕过安全校验，每步单独调用合法但步骤顺序缺失。大模型对业务流程建立有序状态机，实时比对 API 调用序列与预期流程，检测步骤缺失或异常。典型案例：某 OA 系统合同审批需四级审批，攻击者发现 API 仅校验登录状态，以普通员工身份传入 `approve_level=4` 完成审批。大模型通过角色与审批级别的逻辑矛盾、审批流水缺失等交叉验证判定为流程绕过。密码重置绕过同理——检测到“身份验证未完成”下直接出现“设置新密码”的非法跃迁即告警。

3.6.4 技术实现架构

业务逻辑漏洞检测系统采用三层架构：业务上下文采集层从 API 网关和业务数据库获取 API 序列、参数语义、用户角色和行为画像等数据；语义分析引擎以大模型为核心，将 API 调用转化为结构化“业务事件”并检测异常；研判响应模块进行置信度评估，高置信度告警推送至 SOAR 平台。系统采用分层过滤：传统规则层快速过滤明显恶意流量；大模型语义层深度分析；人工研判层对高危异常做最终确认，确保可落地的生产部署。

4 关键技术与实现架构

4.1 检索增强生成技术在安全知识库中的应用

检索增强生成（RAG）是提升大模型安全应用可靠性的关键技术。通用大模型缺乏对企业私有知识的了解且预训练知识存在滞后性。RAG 在模型生成前从外部知识库检索相关信息作为上下文，使模型能基于最新领域知识进行推理。安全运营中将安全策略文档、网络拓扑、历史事件记录和威胁情报等向量化存储，查询时先检索相关文档再与大模型交互，生成基于私有知识的个性化分析结果，弥合通用知识与私有知识的鸿沟，同时提升知识时效性和分析可追溯性。

4.2 智能体在安全自动化中的应用

智能体（Agent）技术赋予大模型规划、工具调用和记忆能力，使其能自主完成多步骤、跨系统的安全运营任务。安全智能体遵循“规划-执行-观察-反思”循环：将复杂任务分解后调用 SIEM、EDR、防火墙等工具 API，观察返回结果并调整计划。以钓鱼邮件处置为例，智能体依次完成 IOC 提取、威胁情报查询、邮箱日志搜索和恶意 IOC 封禁等操作，汇总生成事件处置报告，实现端到端的自动化响应。

4.3 提示工程与安全任务优化

提示工程显著影响大模型安全应用效果，需遵循四项核心原则：角色设定，赋予模型专家身份以引导专业输出；结构化输出，以 JSON 或表格格式输出便于下游自动化；思维链，展示推理过程供分析师验证；多示例学习，提供高质量示例帮助模型理解任务。此外，还需通过输入过滤、输出验证和角色边限定等机制防御提示注入攻击。

5 安全风险与伦理规范

5.1 大模型自身安全风险

大模型引入安全运营的同时也带来新的攻击面。提示注入攻击是最突出的威胁——攻击者构造特殊日志内容或告警描述，当被输入大模型分析时诱导模型输出错误研判或执行未授权操作。此外，模型幻觉问题可能导致看似合理但实际不实的分析结论，使分析师误判事件严重程度。抵御这些风险需在应用中建立多重验证机制，避免模型输出直接驱动关键处置操作。

5.2 数据隐私与合规考量

安全运营数据含网络拓扑和用户行为等敏感信息，传输至外部 API 存在泄露和合规风险。组织需在模型能力与数据安全间权衡：公有云 API 部署便捷但数据外传；私有化部署保证数据不外泄但需相应资源。折中方案采用混合架构——基础分析使用公有云 API，核心数据和关键决策使用私有部署。

5.3 AI 伦理与安全运营中的人机关系

核心伦理问题在于自动化安全决策的边界——AI 能否自主断开服务器网络或封锁大范围 IP？本文认为现阶段大模型在安全运营中的定位应是“智能辅助”而非“自主决策”，关键决策权和执行权仍由人类掌握。“人机协同、人在回路”模式既能发挥 AI 效率优势，又通过人类判断力避免误判和过度响应。安全运营人员需培养对 AI 输出的批判性审查能力。

6 未来展望

大模型在安全运营中的应用将朝三个方向深化：人机协同深度融合，AI 从被动工具演进为主动监控和主动建议的“数字安全分析师”；多模态安全分析崛起，大模型将具备对流量图谱、行为序列和攻击路径等多模态数据的理解能力；自主安全运营初步实现，低风险场景

全自动化闭环，高风险场景保持在回路控制，形成分级自治体系，有效应对安全人才短缺的长期挑战。

7 结论

本文对大模型在安全运营中的应用进行了系统性探讨。研究表明，大模型凭借自然语言理解、逻辑推理和内容生成能力，在威胁检测、事件响应、日志分析、情报处理和安全自动化等环节均展现出重要价值，尤其在业务逻辑漏洞检测这一传统工具盲区中，能有效发现隐藏在正常交互中的越权访问、参数篡改和流程绕过等攻击，填补了基于规则和签名方案的关键空白。RAG 和智能体技术进一步提升了准确性和自主性。同时，本文指出了提示注入、幻觉和数据隐私等不容忽视的风险，强调必须坚持“人机协同、人在回路”原则，确保 AI 应用安全可控。对于信息安全专业学生和从业者而言，掌握大模型在安全运营中的应用，既是对技术趋势的响应，也是为职业发展积累关键能力。

参考文献

- [1] Brown T, Mann B, Ryder N, et al. Language Models are Few-Shot Learners[C]. Advances in Neural Information Processing Systems, 2020, 33: 1877–1901.
- [2] OpenAI. GPT-4 Technical Report[R]. arXiv preprint arXiv:2303.08774, 2023.
- [3] Vaswani A, Shazeer N, Parmar N, et al. Attention is All You Need[C]. Advances in Neural Information Processing Systems, 2017, 30: 5998–6008.
- [4] Lewis P, Perez E, Piktus A, et al. Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks[C]. Advances in Neural Information Processing Systems, 2020, 33: 9459–9474.
- [5] Wei J, Wang X, Schuurmans D, et al. Chain-of-Thought Prompting Elicits Reasoning in Large Language Models[C]. Advances in Neural Information Processing Systems, 2022, 35: 24824–24837.
- [6] Yao S, Zhao J, Yu D, et al. ReAct: Synergizing Reasoning and Acting in Language Models[C]. International Conference on Learning Representations, 2023.
- [7] Ayoobi H, Talebi M, Rahmati M, et al. SecurityBERT: Cyber Security Language Model for Threat Detection[C]. IEEE International Conference on Big Data, 2023: 3651–3660.
- [8] MITRE Corporation. ATT&CK Framework for Enterprise[EB/OL]. <https://attack.mitre.org/>, 2024.
- [9] OWASP Foundation. OWASP Top 10 for Large Language Model Applications[EB/OL]. <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, 2024.
- [10] 张勇, 李华, 王强. 大语言模型在网络安全领域的应用综述[J]. 计算机学报, 2024, 47(3): 521–545.
- [11] OWASP Foundation. OWASP API Security Top 10 2023[EB/OL]. <https://owasp.org/API-Security/editions/2023/>, 2024.